

Politique de sécurité de l'information — Horizon

Organisation : Vibe Coding Mind **Application** : Horizon (gestion de finances personnelles pour couples)

Responsable de la sécurité et de la protection des renseignements personnels : Sébastien Normandeau — sebastiennormandeau@gmail.com **Version** : 1.2 — 22 juillet 2026 · **Prochaine revue** : juillet 2027 (revue annuelle obligatoire) *Journal* : 1.1 — *double authentification obligatoire pour tous les comptes utilisateurs et procédure de réinitialisation administrateur (§6 bis)*. 1.2 — `horizon-dbba0` devient un environnement de pilote restreint hébergeant de vraies données bancaires pour un nombre fermé de comptes nommés (§4).

Cette politique s'applique à l'ensemble des systèmes d'Horizon : application Flutter (Android, iOS, Web), Cloud Functions, bases de données Firestore, intégrations tierces (Plaid, RevenueCat, Anthropic) et postes de travail utilisés pour le développement.

1. Contrôle d'accès

- **Moindre privilège.** Chaque utilisateur de l'application n'accède qu'aux données de son propre foyer, appliqué par les règles de sécurité Firestore (`firestore.rules`) côté serveur — jamais uniquement côté client.
- **Authentification des utilisateurs** : Firebase Identity Platform (courriel/mot de passe, 8 caractères minimum avec lettres et chiffres), **vérification du courriel obligatoire** appliquée en trois couches (client, Cloud Functions, règles Firestore), et **double authentification (TOTP) obligatoire pour tous les comptes** — imposée côté serveur et matérialisée par une porte d'enrôlement bloquante dans l'application. La réinitialisation d'un facteur perdu relève d'une procédure administrateur hors application (voir §6bis).
- **Données sensibles inaccessibles aux clients** : les jetons d'accès bancaires Plaid (`bank_connections`) et les compteurs de limitation (`rate_limits`) sont en interdiction totale de lecture/écriture ; seules les Cloud Functions (Admin SDK) y accèdent.
- **Accès internes (consoles d'administration)** : réservés au responsable nommé ci-dessus. L'**authentification multifacteur (MFA) est obligatoire** sur tous les comptes d'administration : compte Google (Firebase / Google Cloud), GitHub, tableau de bord Plaid, RevenueCat et Console Anthropic.
- **Anti-abus** : App Check (attestation d'appareil), limitation de débit par utilisateur sur toutes les fonctions appelables (fenêtre glissante), validation systématique des entrées côté client et côté serveur.

2. Chiffrement et protection des données

- **En transit** : TLS (HTTPS) sur toutes les communications — application, API Firebase/Google Cloud, Plaid, RevenueCat, Anthropic.
- **Au repos** : chiffrement par défaut de Google Cloud sur Firestore, Secret Manager et les sauvegardes.
- **Identifiants bancaires** : jamais collectés ni stockés par Horizon — la connexion bancaire passe par Plaid ; seuls des jetons d'accès révocables sont conservés, hors de portée des clients.
- **Minimisation** : le coach IA ne reçoit que des agrégats anonymisés (aucun identifiant personnel, aucune transaction brute), tel que documenté dans la politique de confidentialité (§3).

- **Webhooks authentifiés** : Plaid (signature JWT ES256, hachage du corps, fraîcheur ≤ 5 min) et RevenueCat (secret d'autorisation dédié).

3. Gestion des secrets

- Les secrets d'exploitation (PLAID_CLIENT_ID, PLAID_SECRET, REVENUECAT_WEBHOOK_AUTH, ANTHROPIC_API_KEY) résident exclusivement dans **Google Secret Manager** et sont injectés aux fonctions au déploiement.
- **Aucun secret dans le dépôt Git**, dans le code client ou dans les journaux. Les clés publiques (Firebase, SDK RevenueCat, reCAPTCHA) sont injectées par `--dart-define` et restreintes dans la console Google Cloud.
- **Rotation** : immédiate en cas de suspicion de fuite (voir §6) ; les jetons Plaid d'un utilisateur sont révoqués (`itemRemove`) à la suppression de son compte.

4. Sécurité du développement

- **Environnements** : `horizon-dbb0` est un **environnement de pilote restreint**. Depuis le 22 juillet 2026, il est raccordé à Plaid en accès production limité et héberge donc de vraies données bancaires, pour un nombre fermé de comptes nommés appartenant au responsable et à son foyer. Il n'est pas ouvert au public et aucune inscription externe n'y est sollicitée. Les mesures de la présente politique — MFA obligatoire, chiffrement, cloisonnement par foyer, jetons bancaires inaccessibles aux clients — s'y appliquent intégralement, sans exception « parce que c'est du développement ». Le projet de production distinct (`horizon-prod`, `--dart-define=APP_ENV=prod`) reste prévu avant toute ouverture au public ; les données du pilote ne seront pas migrées. ⚠ *Corollaire assumé* : cet environnement contenant désormais des données réelles, ses sauvegardes (PITR et sauvegardes planifiées) doivent être actives — voir `PRODUCTION_CHECKLIST.md` §7.
- **Intégration continue** obligatoire sur chaque changement : analyse statique Flutter (0 avertissement toléré), tests unitaires, compilation TypeScript des fonctions et **audit des dépendances npm**.
- **Gestion des vulnérabilités des dépendances** : Dependabot surveille les écosystèmes npm (fonctions), pub (Flutter) et GitHub Actions, avec correctifs hebdomadaires ; `npm audit` bloque le CI en présence de vulnérabilités de sévérité élevée ou critique.
- Toute nouvelle fonction appellable doit appliquer l'authentification (`requireAuth`), la limitation de débit (`enforceRateLimit`) et la validation des entrées (`assertString` + motifs).

5. Postes de travail

Tout poste utilisé pour développer ou administrer Horizon doit avoir : mises à jour automatiques du système d'exploitation activées, **chiffrement intégral du disque** (BitLocker sur Windows / FileVault sur macOS), protection antimaliciel active (Microsoft Defender ou équivalent), et verrouillage de session automatique.

Ces postes hébergent des identifiants d'administration à protéger comme des secrets : jeton du CLI Firebase et **identifiants par défaut de l'application Google Cloud** (`%APPDATA%\gcloud\application_default_credentials.json` sur Windows), ce dernier donnant accès à Identity Platform — dont le pouvoir de réinitialiser un second facteur (§6 bis). Le chiffrement du disque est donc la

mesure qui protège cette chaîne. En cas de perte ou de vol du poste : révoquer immédiatement ces identifiants (`gcloud auth application-default revoke` , `firebase logout`) et appliquer la procédure du §6.

6. Réponse aux incidents

En cas d'incident de sécurité (fuite de secret, accès non autorisé, vulnérabilité exploitée) :

1. **Contenir** : révoquer/faire pivoter immédiatement les secrets touchés (Secret Manager, clés API des consoles), désactiver les jetons Plaid concernés, suspendre les comptes compromis. 2. **Évaluer** : déterminer les données touchées, la période et les foyers concernés à partir des journaux (Cloud Functions, Firestore, Crashlytics). 3. **Notifier** : si l'incident de confidentialité présente un **risque de préjudice sérieux**, aviser la Commission d'accès à l'information du Québec et les personnes concernées, conformément à la **Loi 25** ; informer Plaid si des données bancaires sont en cause. 4. **Documenter** : tenir un registre des incidents de confidentialité (obligation Loi 25) — date, nature, données visées, mesures prises. 5. **Corriger** : éliminer la cause racine, ajouter un test ou un contrôle empêchant la récurrence.

6 bis. Réinitialisation d'un second facteur (MFA)

Le TOTP n'a aucune récupération intégrée : un utilisateur privé de son application d'authentification est définitivement bloqué sans intervention.

- **Le pouvoir de réinitialisation vit hors de l'application** — script local `functions/scripts/mfa-admin.js` , jamais déployé, exigeant les identifiants Google administrateur (eux-mêmes protégés par MFA). Aucune fonction « admin » n'est exposée sur Internet.
- **Vérification d'identité obligatoire par un canal indépendant du courriel** (appel téléphonique, question de sécurité convenue) avant toute réinitialisation. Une demande reçue par courriel ne prouve rien : la compromission d'une boîte courriel est précisément la menace contre laquelle le second facteur protège.
- **Traçabilité** : chaque réinitialisation est consignée (date, compte visé, demandeur, moyen de vérification employé) dans le registre tenu au titre du §6. Le script révoque également les jetons de session existants.
- **Après réinitialisation**, la porte d'enrôlement de l'application force immédiatement la mise en place d'un nouveau facteur.

7. Cycle de vie des données

- **Conservation** : les données transactionnelles et budgétaires sont conservées tant que le compte est actif.
- **Droit d'accès et de portabilité** : export JSON complet en libre-service (Réglages → « Exporter mes données »).
- **Droit à l'effacement** : suppression de compte en libre-service — révocation des jetons Plaid, effacement des transactions, du profil et du compte d'authentification.
- **Sauvegardes** : récupération à un instant passé (PITR) et sauvegardes planifiées sur le projet de production, avec test de restauration trimestriel (voir `PRODUCTION_CHECKLIST.md` , §7).

8. Revue de la politique

Cette politique est revue **au moins une fois par année** par le responsable, ainsi qu'après tout incident majeur ou changement significatif d'architecture. Chaque revue met à jour la version et la date en tête du document.